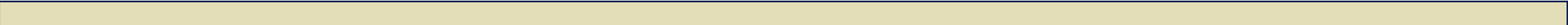


Sicurezza nelle Reti di Computer

Attacchi e Difese



Outline

- Aspetti di sicurezza nelle reti

 - ➞ Vulnerabilità e principali attacchi

- Firewall

- Protocolli di rete con crittografia

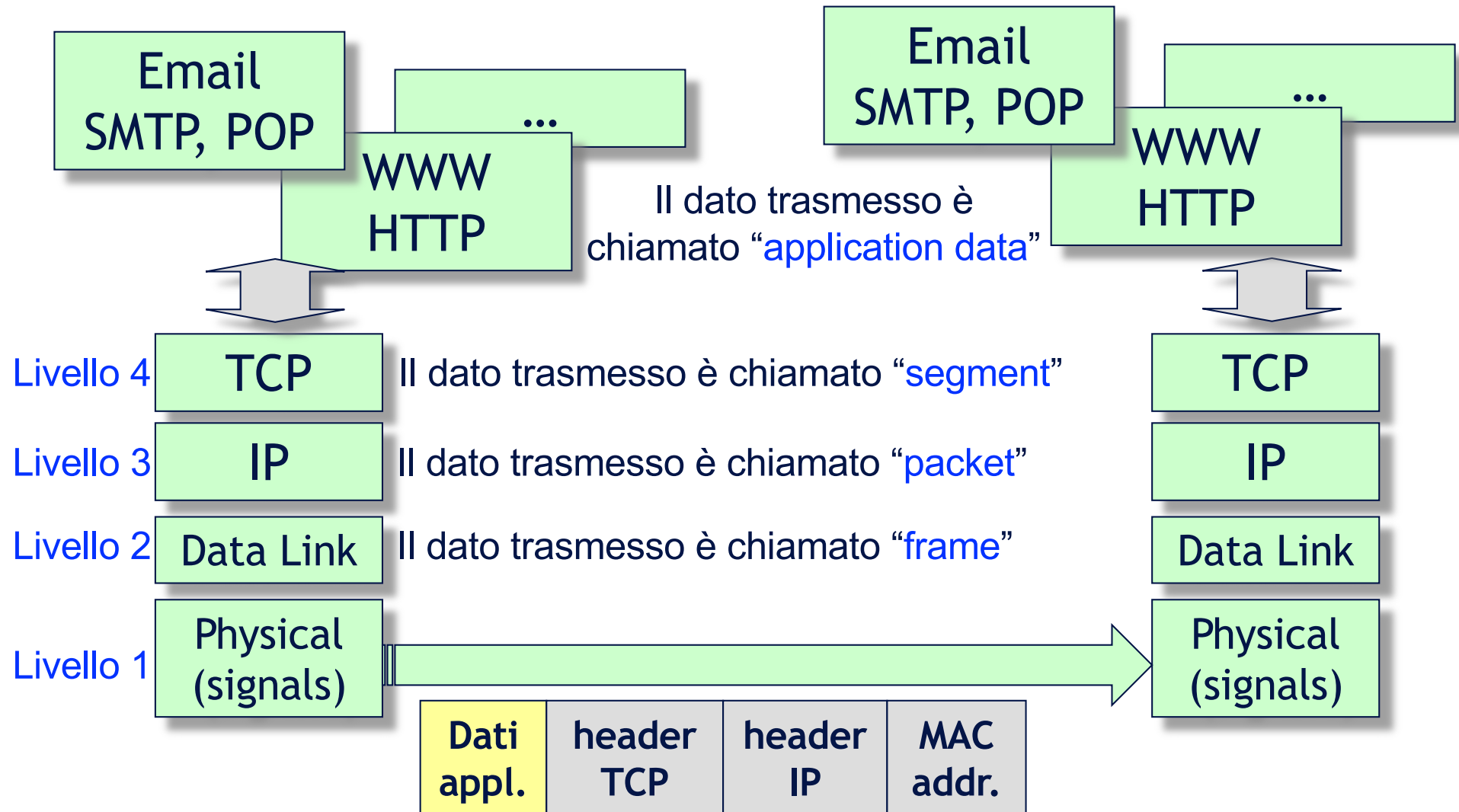
 - ➞ Protocolli di trasporto per la sicurezza

 - ➞ Protocolli di rete per la sicurezza

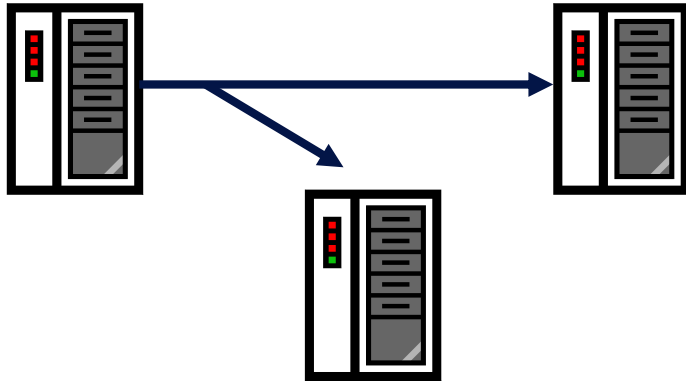
Obiettivi della sicurezza nelle reti

- Gli stessi del caso single host
 - ➔ Confidenzialità
 - ➔ Integrità
 - ➔ Disponibilità
 - ➔ Controllo degli accessi
 - ➔ Autenticazione/Non ripudio
- Però... esposizione maggiore ad attacchi maliziosi
 - ➔ Un computer in rete è accessibile da milioni di altri computer attraverso Internet
 - ➔ I messaggi scambiati attraverso la rete attraversano molti nodi intermedi non controllabili
 - ➔ La comunicazione è gestita da software per cui è più semplice automatizzare gli attacchi

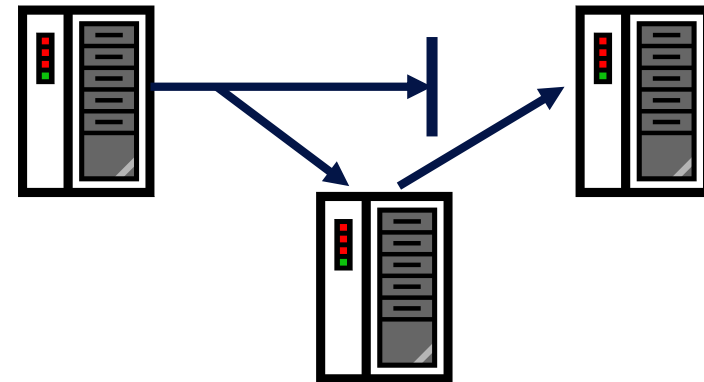
Trasmissione Dati in Rete



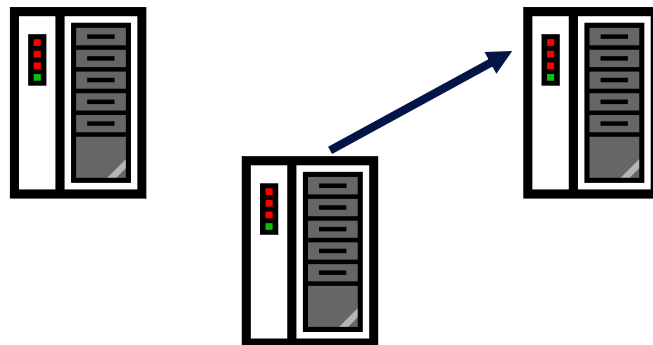
Violazioni di sicurezza



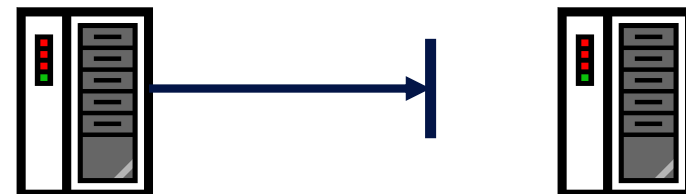
**Intercettazione
(confidenzialità)**



**Modifica dei dati
(integrità)**

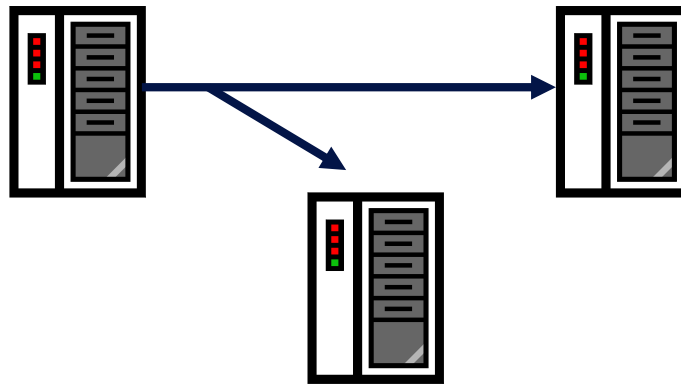


**Creazione di traffico
(integrità)**



**Denial of service
(disponibilità)**

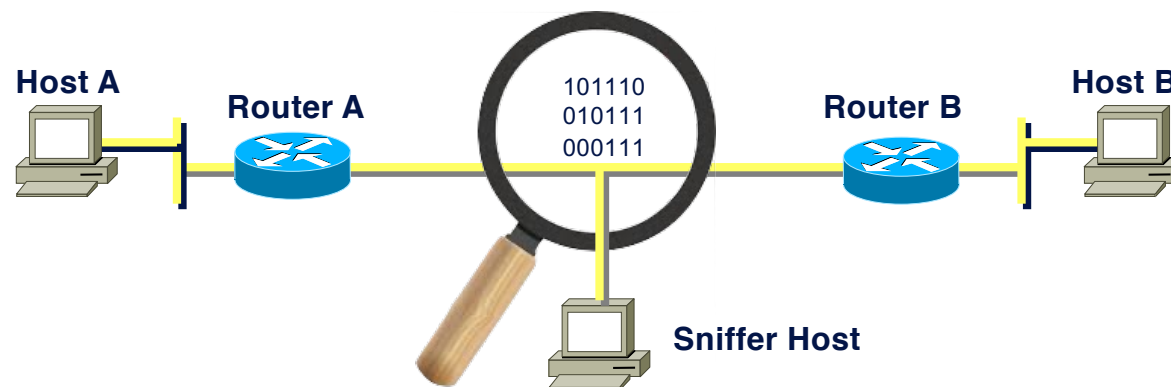
Principali attacchi: Ascolto



Wiretap passivo, Intercettazione, Sniffing

Watching Traffic: Sniffing

- A sniffer is a software application that is capable of **acquiring packets at the datalink level**
- It is able to interpret and **show the in-clear information relating to level 2, 3 and 4 packet headers** as well as application level protocols such as: FTP, HTTP, etc.
- A network adapter (e.g., Ethernet) set in **promiscuous mode** reads all packets in transit



Applications of Sniffing

■ Automatic network analysis

- ➞ searching for specific patterns e.g., clear passwords and usernames: this is a common use for hackers / crackers;

■ Anomaly analysis

- ➞ in order to find out any problems within the networks, such as, why computer A cannot communicate with computer B;

■ Performance analysis

- ➞ to discover problems or bottlenecks in networks;

■ Network monitoring (defensive)

- ➞ to detect attacks or threats, as well as malicious activities in progress;

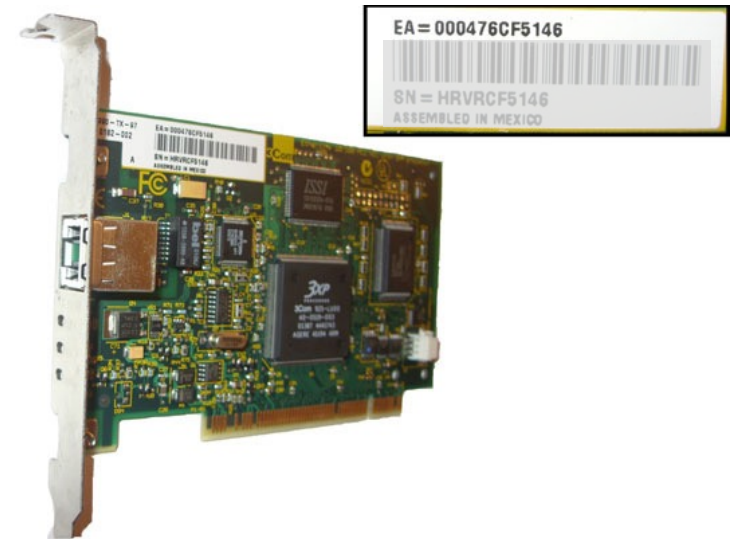
■ Recording of network traffic

- ➞ to create logs of network transactions available for subsequent "post-mortem" analysis.

Layer 2: Ethernet

Ethernet is a broadly deployed layer 2 protocol

- Encapsulates and transmits data in the form of *frames*
- Frames leverage the **Media Access Control (MAC) addresses**
 - ➔ 48 bits burned in the adapter ROM (first 3-bytes are the ID of the manufacturer* - called OUI: Organization Unique Identifier)
 - ➔ Every Ethernet device (e.g., on a PC, a server, a router) has a unique MAC address on its local network
 - ➔ A *Frame* includes the MAC address of the destination Ethernet interface on the target system as well the MAC address of the source Ethernet interface on the sending system



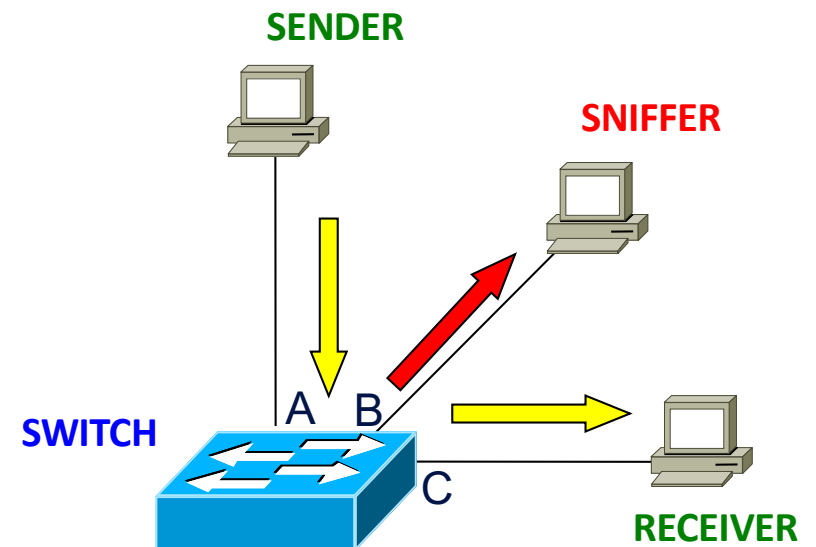
*<https://www.wireshark.org/tools/oui-lookup.html>

Sniffing on non-switched LAN

- In a non-switched LAN (local area network)
 - ➔ All nodes share the same transmission medium
 - ➔ Usually a layer-2 network adapter (e.g., Ethernet) selects only packets that correspond to its MAC address
 - ➔ However, a network adapter (e.g., Ethernet) set in **promiscuous mode** will read all packets in transit
 - ➔ The intercepted packets contain all metadata of network protocols (e.g., IP addresses, TCP ports, ...) and application data (user data)

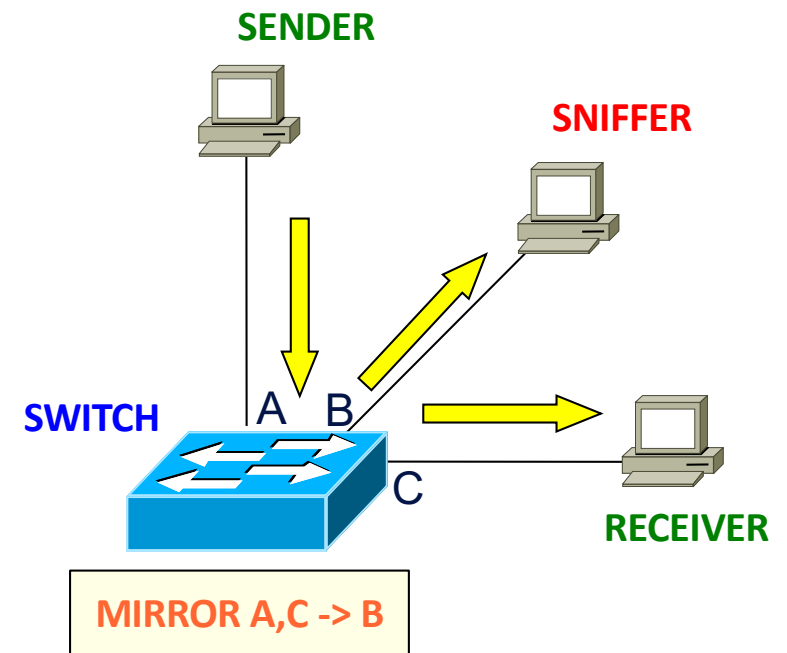
Sniffing on switched networks

- On switched networks, traffic is transmitted according to the MAC address + Port association, excluding terminals not interested in traffic
- A sniffer is only able to intercept the traffic destined to its host
- ...but there are ways to enable sniffing



Sniffing on switched networks

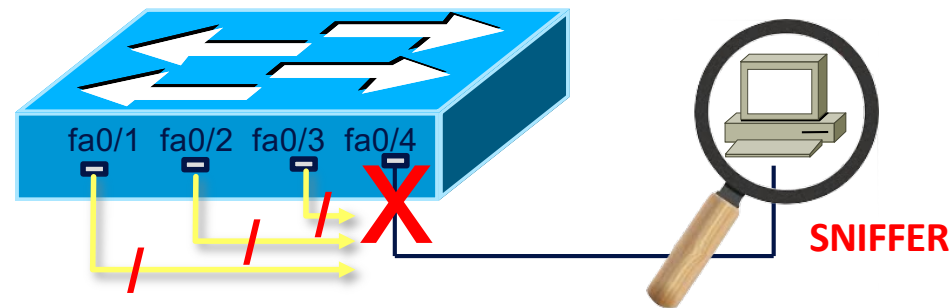
- ...
- A sniffer is only able to intercept the traffic destined to its hosting
- ...but there are ways to enable sniffing
- **Way 1:** configure the switch port to which the sniffer is connected in **mirroring mode**
 - ➔ The switch will replicate the traffic received from any port on the sniffer port



Sniffing without port mirroring

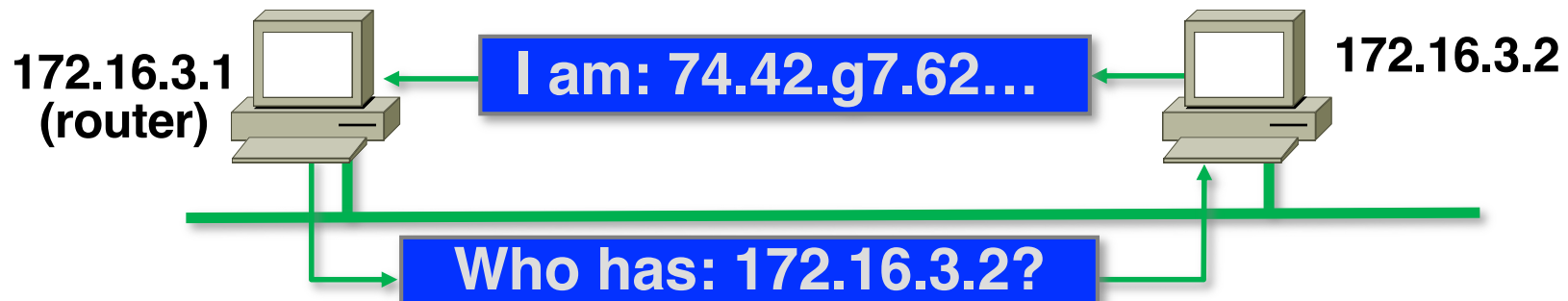
■ If port mirroring capabilities is not available, possible options include:

- ➡ Use repeater devices (limited bands)
- ➡ Use dedicated HW probes (TAP)
- ➡ **Perform traffic diversion through specific attacks (ARP Poisoning)**



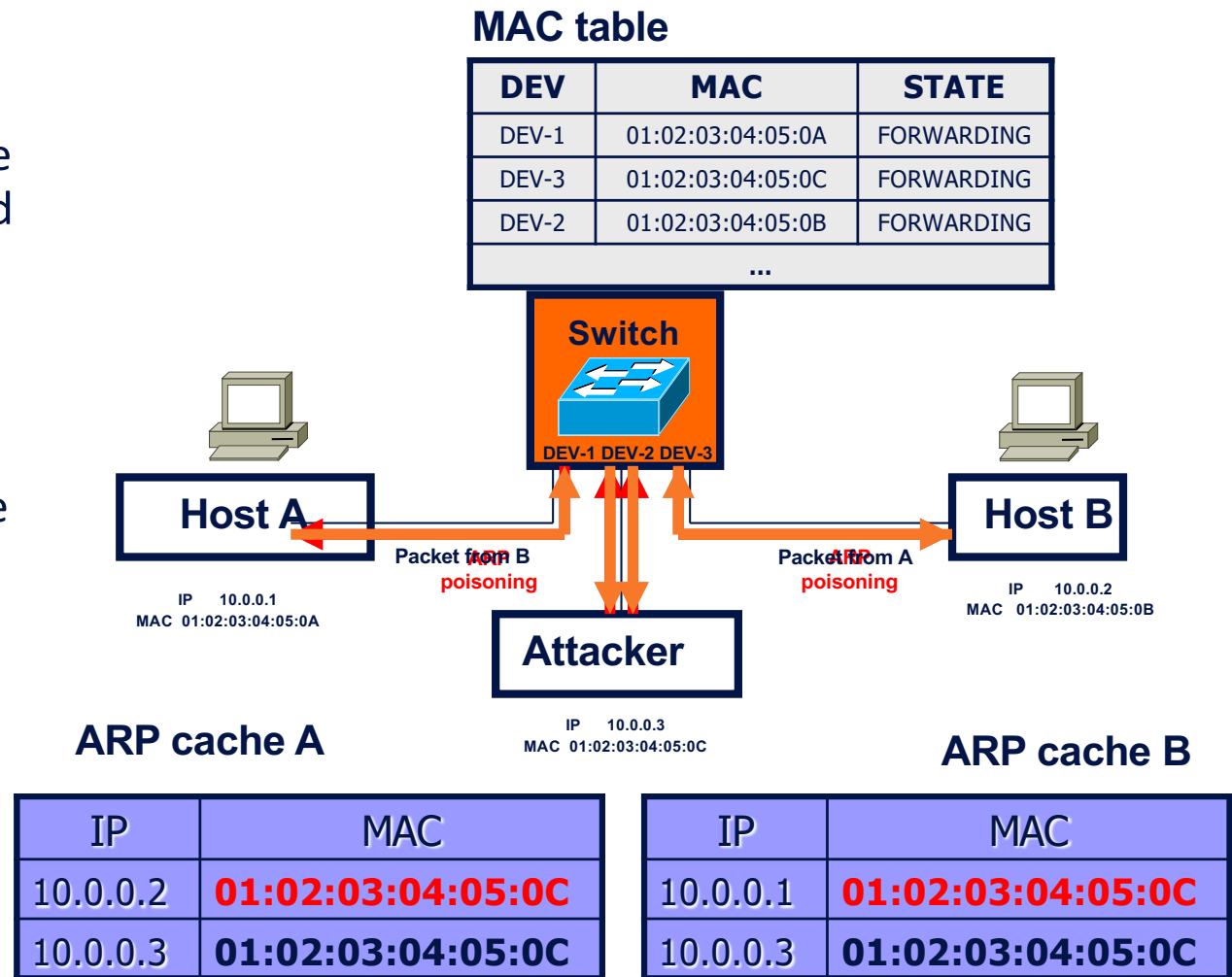
ARP

- The Address Resolution Protocol (ARP) is concerned with mapping the 32 bits of IP address (version 4) into 48 bits of ETH address (MAC)
- Two main types of messages:
 - ARP request (request for IP address resolution)
 - ARP reply (reply containing an eth address)
- The replies are stored in the ARP CACHE, to limit traffic on the network



ARP poisoning

- Takes advantage of the stateless behavior of the protocol
- ARP replies are saved in cache even if they were not solicited
- If the attacker sends an **ARP reply (spoofed)** to a router, this will save it in his ARP cache
- The attacker now receives the packets sent to the spoofed address. Moreover, the attacker can forward the packets to the correct destination
- The cache entries are timed out, so the attacker must periodically "refresh»



Network address spoofing

- Attacks that exploit the stateless nature of the network protocols
 - Stateless = each packet is interpreted as it is, just based on the data it contains
 - Attackers can deliberately set arbitrary any source addresses
 - Victims interpret each packet as it came from the source address written within the packet itself
- ARP spoofing (MAC address spoofing): The attacker sets a spoofed source MAC address within the layer-2 header
- IP spoofing: The attacker sets a spoofed source IP address within the layer-3 header

Defenses against ARP poisoning

■ Static ARP entries

- ➔ statically entered, readonly IP address-to-MAC address mappings in the local ARP cache
- ➔ maintenance issues: address mappings must be generated and distributed.

■ Detection and prevention software

- ➔ The existence of multiple IP addresses associated with a single MAC address may indicate an ARP spoofing attack
- ➔ (although there can be legitimate uses of such a configuration)

■ OS security (different OS takes different choices)

- ➔ ignore unsolicited replies
- ➔ accepts updates on entries only after a timeout

Principali attacchi: Ascolto

■ Wiretap passivo

➔ Intercettazione attraverso sniffing dei pacchetti che transitano in rete

...ma anche

➔ Rough wireless access point

➔ Mezzi fisici: “lettura” per induzione elettromagnetica, alterazione del cavo, intercettazione di comunicazione wireless/satellite mediante antenne

➔ Analisi del traffico di rete: l'obiettivo non sono solo i dati, ma anche i metadati di una comunicazione (es: indirizzi sorgente e destinazione)

**Violazioni di
confidenzialità**

Principali attacchi: Wiretap attivo

■ Wiretap attivo

- ➔ Invio di falsi messaggi
- ➔ Modifica (parziale) di contenuto e metadati
- ➔ Replay di precedenti messaggi
- ➔ Reindirizzamento dati/messaggi
- ➔ Eliminazione dati messaggi

**Violazioni di
integrità**

**Violazioni di
disponibilità**

Principali attacchi: Falsificazione di identità

- Spoofing: In generale ci si riferisce a falsificazioni di identità (per invio/furto di informazioni)
 - ➔ Pharming: nodo della rete che impersona un altro nodo
 - ➔ Phishing: spesso passo preliminare di un attacco pharming
 - ➔ **IP Spoofing**
 - ➔ **Fake public key identity**: per realizzare wiretap attivo/passivo in protocolli che fanno uso di crittografia
 - ➔ **Hijacking di sessione**

**Tecniche utili
in attacchi per
realizzare
violazioni di
sicurezza**

Spoofing: Pharming

- Host che si finge un altro host (in cui gli utenti hanno fiducia)
 - ➔ Per esempio per furto di dati riservati (codici, password...)
- Di solito l'attaccante cerca di replicare il medesimo scenario applicativo dell'host vero
(esempio: riproducendo la stessa grafica di un sito web)
in modo da non far notare il “camuffamento”
- Modalità
 - ➔ Sfruttando confusione fra URL con nomi simili
 - ➔ Alterando le tabelle di un DNS (server dei nomi di dominio)
 - ➔ Sfruttando phishing

Spoofing: Phishing

From: First Generic Bank <accounts@firstgenericbank.com>
Subject: Please update your account information
Date: Sep 12, 2006 3:23 PM PST

Dear First Generic Bank user,

As a courtesy to our valued customers, First Generic Bank conducts regular account information verification processes. During the most recent process, we found that we could not verify your information.

In order to ensure your account information is not made vulnerable, please visit <http://www.firstgenericbank.com.account-updateinfo.com>.

Please click on the above link to our Web site and confirm or update your account information. If you do not do this within 48 hours of receipt of this e-mail, you will not be able to use your First Generic Bank account for 30 days. This is an extra precaution we take to ensure your account remains secure.

Sincerely,

First Generic Bank



Giovanni Denaro

Re:

To: Prof PASI GABRIELLA

sì, ci sono

g.

On 28 Apr 2021, at 15:44, Prof PASI GABRIELLA <prof.gabriella.pasi.unimib.it@gmail.com> wrote:

Ciao sei disponibile?

Per favore, ho bisogno urgentemente della tua assistenza

Professor PASI GABRIELLA

Role:

Full professor

Organizational position:

Pro-Rector for Internationalization

Department Director (DEPARTMENT OF COMPUTER SCIENCE, SYSTEMS AND COMMUNICATION)

Room:

U14, Floor: P02, Room: 2009

Viale Sarca, 336 - 20126 MILAN

University of Milan-Bicocca

Piazza dell'Ateneo Nuovo, 1 - 20126, Milan



Giovanni Denaro

Re:

To: Prof PASI GABRIELLA



Prof PASI GABRIELLA

28 April 2021 at 15:53

Re:

To: Giovanni Denaro

Grazie per la tua risposta, per favore sono in riunione in questo momento, ecco perché ti sto contattando tramite qui Avrei dovuto chiamarti ma il telefono non può essere usato durante la riunione Non so quando la riunione sarà in tondo su e voglio che mi aiuti subito su qualcosa di molto importante c'è qualche negozio di alimentari vicino a te?

Professor PASI GABRIELLA

Role:

Full professor

Organizational position:

Pro-Rector for Internationalization

Department Director (DEPARTMENT OF COMPUTER SCIENCE, SYSTEMS AND COMMUNICATION)

Room:

U14, Floor: P02, Room: 2009

Viale Sarca, 336 - 20126 MILAN

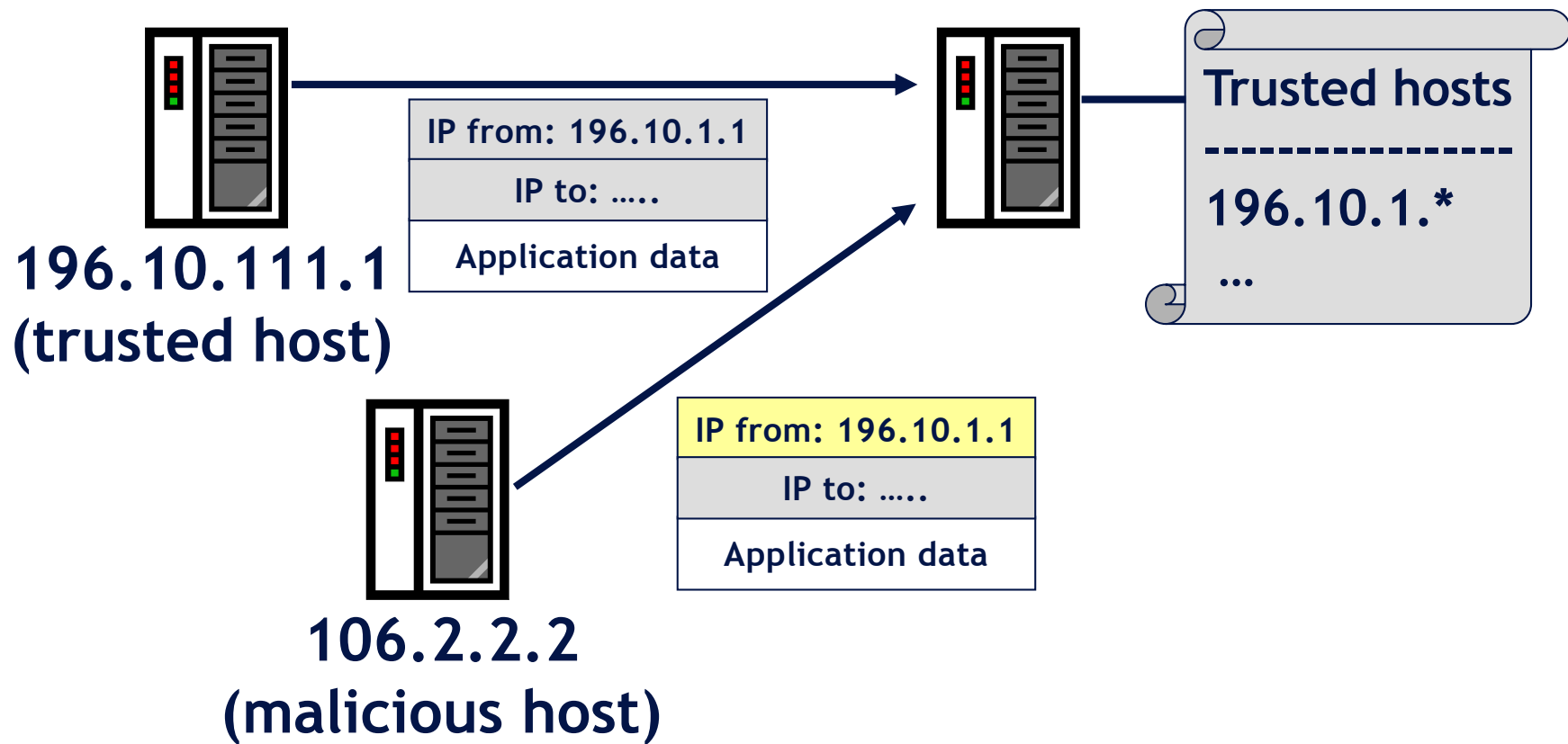
University of Milan-Bicocca

Piazza dell'Ateneo Nuovo, 1 - 20126, Milan

IP spoofing

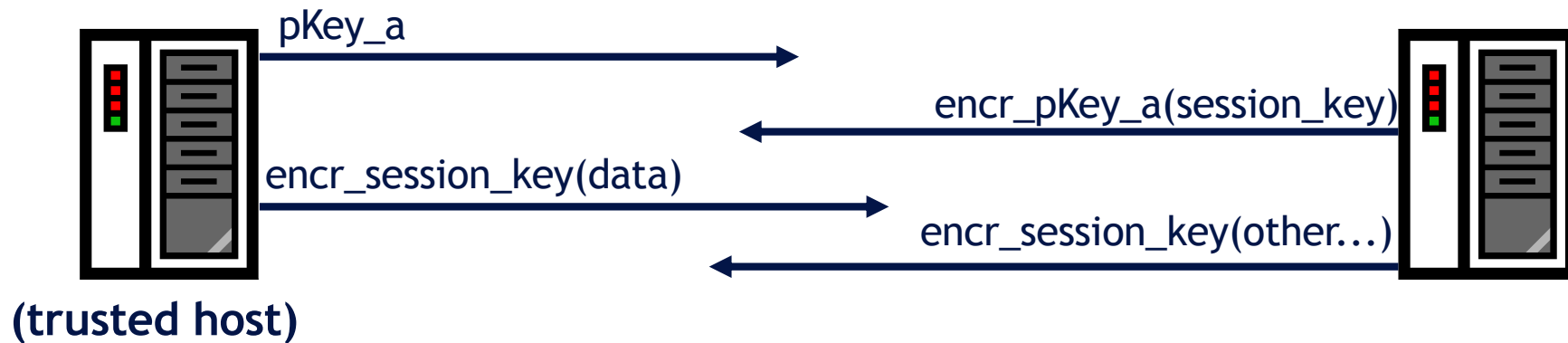
■ IP spoofing

- ➔ Creazione di traffico IP con un indirizzo di sorgente falso, (es. un indirizzo che non ha bisogno di autenticazione)

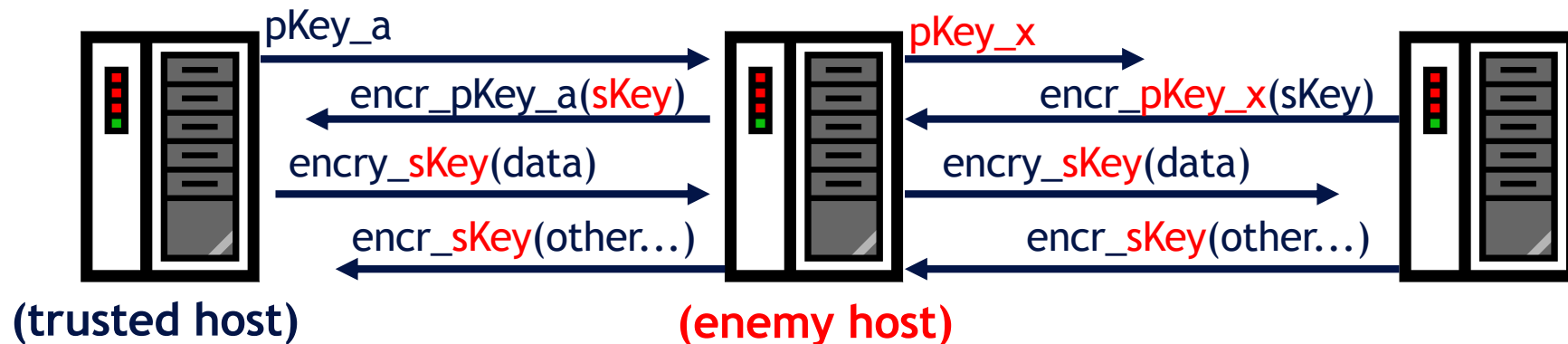


Spoofing: Fake public key identity

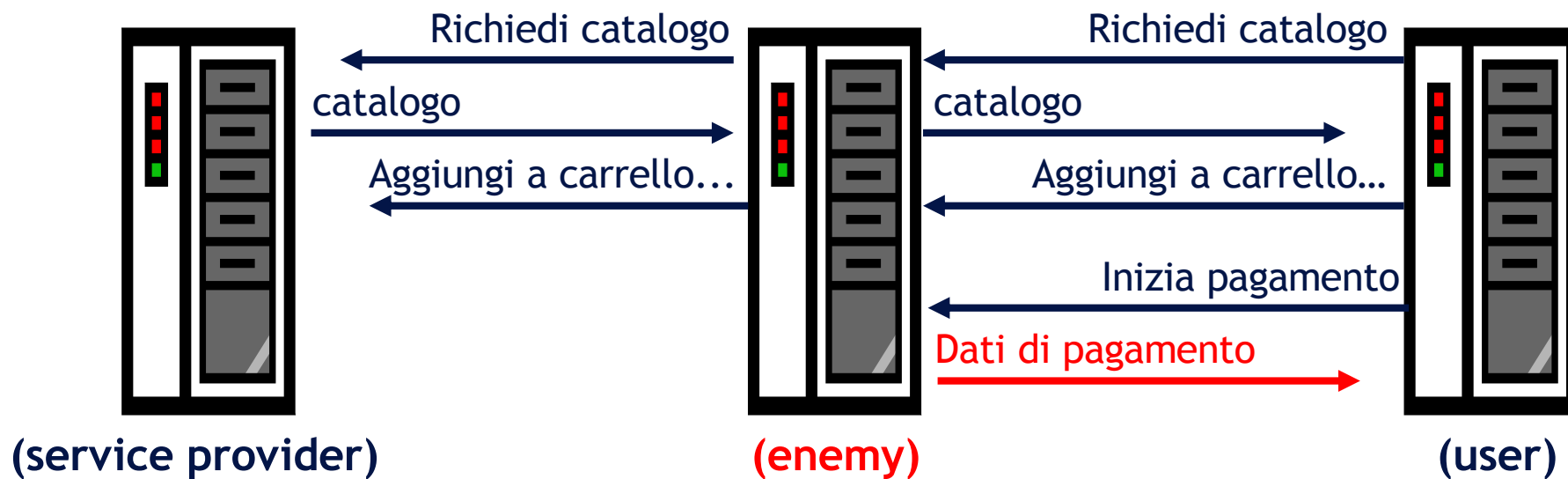
Comunicazione normale



Attacco man in the middle

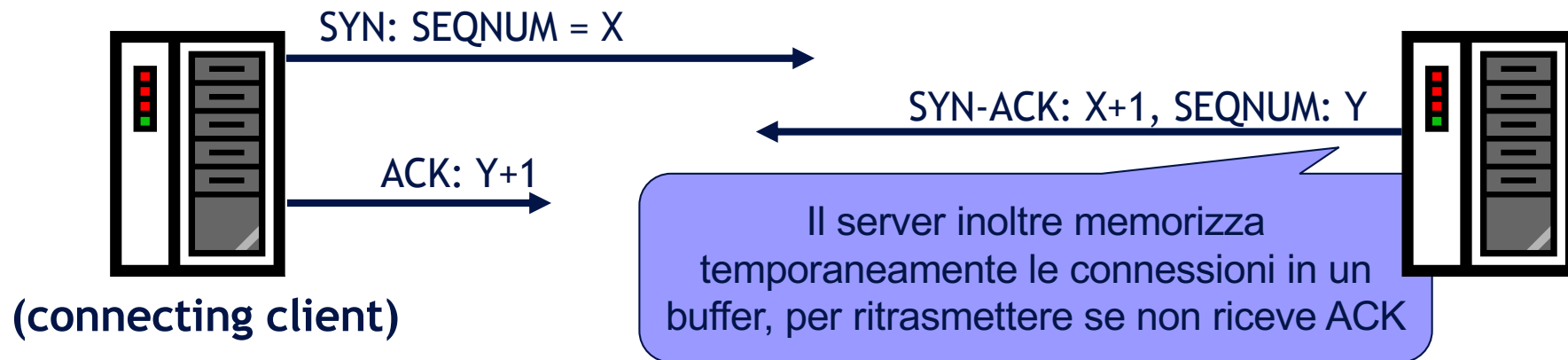


Spoofing: Hijacking di sessione

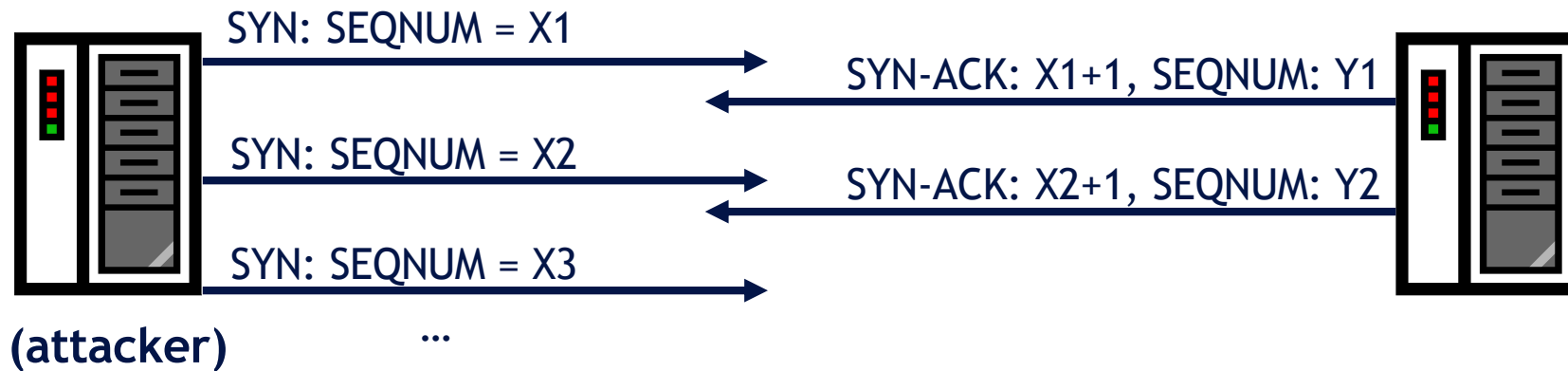


Denial of Service, Esempio: Syn Flood

All'instaurazione di connessioni TCP



Syn-flooding



Principali attacchi: Denial of Service

■ DoS: Denial of Service

- ➔ Attacchi fisici a computer e apparati di rete (solitamente prevedibili o difficili da attuare)
- ➔ Flooding
 - Syn flooding su TCP/UDP
 - Flooding attraverso protocolli ICMP come “ping”
 - Smurf:
Ping broadcast + IP spoofing
- ➔ Attacchi DDoS (Distributed DoS):
cavalli di troia (zombie) + Flooding
- ➔ Attacchi DNS:
reindirizzamento del traffico attraverso modifiche su server dei nomi

**Violazioni di
disponibilità**

Prima dell'attacco...

- Scansione delle porte
- Ingegneria sociale (intelligence)
- OS/Application fingerprint
- Studio debolezze da documentazione software
- Studio debolezze note (info in rete)
- ...

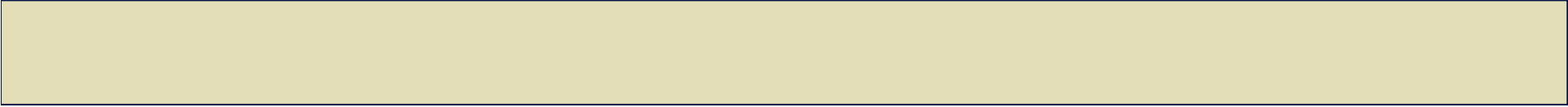
Social Engineering

Furba e intelligente manipolazione della naturale tendenza umana alla fiducia (molti attacchi avvengono per telefono)

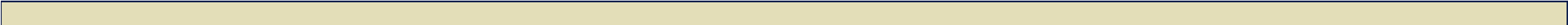
■ Esempi

- ➔ Ottenere accesso non autorizzato ad un edificio sostenendo di aver perso il proprio badge
- ➔ Ottenere informazioni riservate per telefono fingendosi un'altra persona
- ➔ Indovinare la password di un utente con un dizionario di parole comuni perché l'utente ha scelto una password troppo semplice
- ➔ Scoprire la password che un utente usa su un sito insicuro e poterla usare per accessi più importanti perché l'utente usa sempre la stessa password
- ➔ Apertura di allegati email contenenti virus

Spesso importanti problemi di sicurezza hanno a che fare con le persone che usano il sistema più che con la tecnologia!!!



DIFESE CONTRO ATTACCHI DALLA RETE



Difese contro attacchi dalla rete

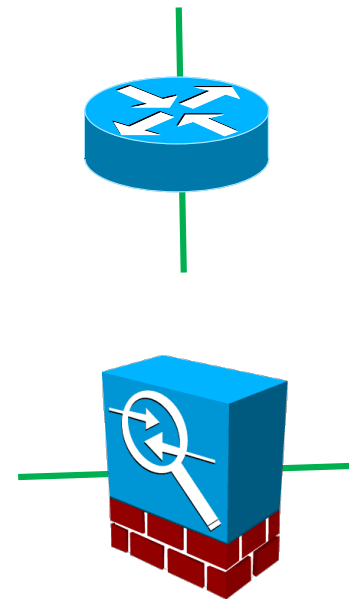
- Molti attacchi possono essere prevenuti attraverso attento management di sistemi e utenti
 - ➔ Applicazione tempestiva di Security patches
 - ➔ Attenta (ri-)configurazione software/servizi/topologia della rete
 - ➔ Re-istallazione frequente (se e dove possibile)
 - ➔ Uso di network scanners che cercano vulnerabilità
 - ➔ Corporate security policies and staff training
- Filtering/firewalling/Intrusion detection
- Protocolli di rete che usano encryption
- ...

Security enforcement devices

- A typical security architecture implements security policies by relying on perimeter control devices

- ➔ **Routers** (typically those located on the network border)

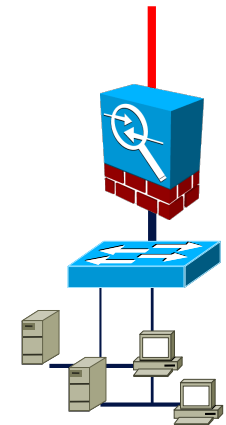
- ➔ **Firewalls**



Disclaimer: Border routers and Firewalls designate different HW devices. However, most of functionalities of a firewall can be implemented in a border router.

Firewall

- Literally «isolation barrier from fire»
- It is the main passive perimeter defense component
- It takes security enforcement tasks, controlling traffic between two or more networks:
 - ➔ allowing only what is specifically authorized by the security policy
 - ➔ detecting and reporting attempts to violate the security policy
 - ➔ carrying out auditing and accounting functions
 - ➔ connecting network segments at the data-link or network layer

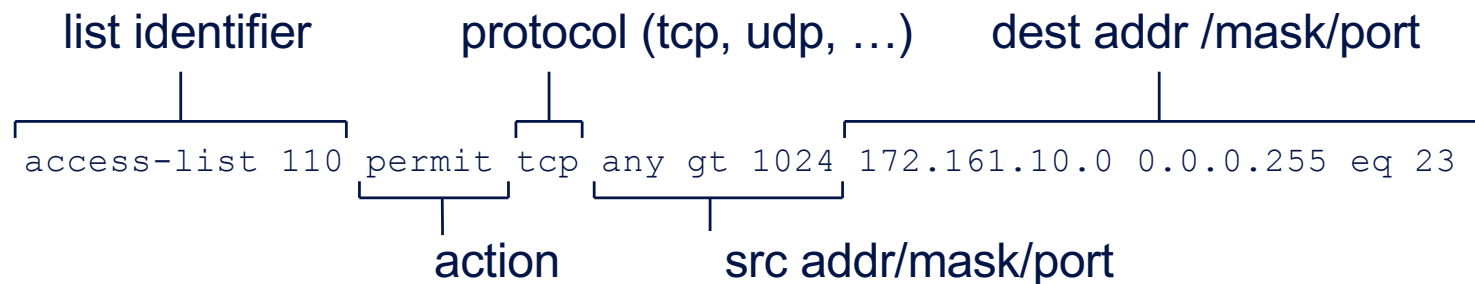


Firewall types

- **Packet filter** (usually stateless)
 - Works on level-2 or level-3 data
 - Monitoring IP and TCP headers of packets (IP addresses, TCP ports)
- **Application Gateway** (usually statefull)
 - Work at the level of application protocols
 - Monitoring the application data (across multiple packets) semantically

Packet filtering

- The simplest and most immediate way to implement security schemes and policies is packet filtering
- Routers, switches and firewalls support lists of filtering (or access control) rules
- Filtering rules that **will be checked sequentially** against each packet, to select the first matching rule (if any)
- Each filtering rule may define either a **permit** (allow) and a **deny** (drop) action



- E.g to block non-trusted traffic

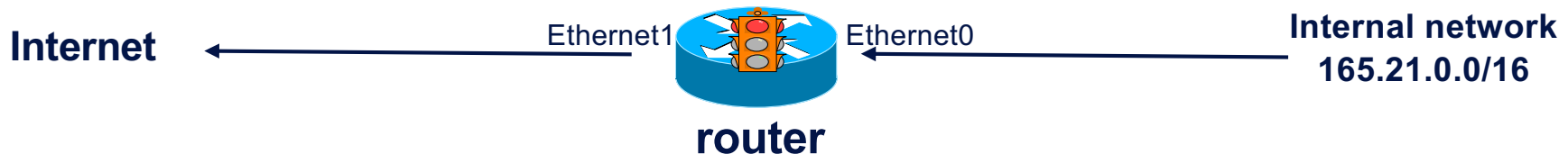
Packet Filtering example

Anti-spoofing filtering (for traffic coming from internal hosts)

- Prevents voluntary/involuntary spoofing from inside of network to the outside
RFC 2827: A border router forwards only packets with legitimate source addresses

```
interface Ethernet0
    ip access-group 111 in  # blocks traffic spoof entering from eth0

! Block outgoing traffic with foreign source IPs:
access-list 111 permit ip 165.21.0.0 0.0.255.255 any
access-list 111 deny ip any any log
```



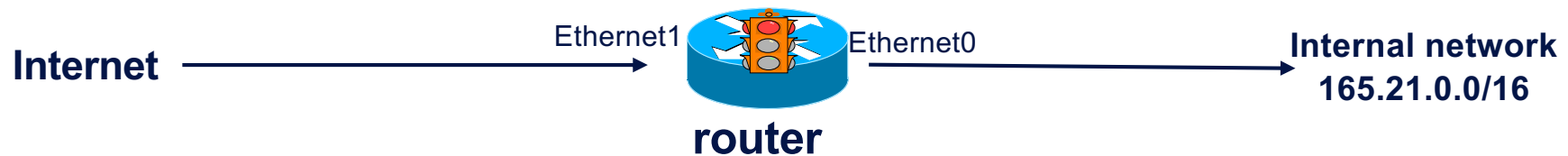
Packet Filtering example

Anti-Spoofing filters (for traffic coming from external hosts)

- The easiest way to protect yourself is to discard all incoming traffic with inadmissible source addresses with respect to the traffic origin side

```
interface Ethernet1
    ip access-group 110 in # blocks traffic spoof entering from eth1

! Block traffic from the outside with internal source addresses:
access-list 110 deny ip 165.21.0.0 0.0.255.255 any
access-list 110 permit ip any any
```

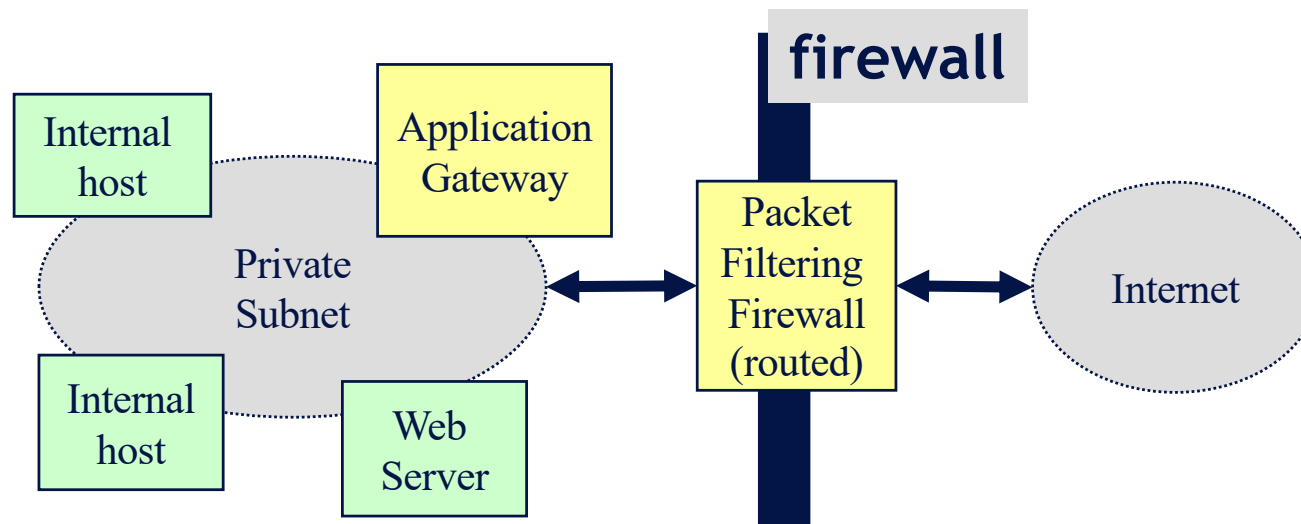


Application gateway (Proxy)

- Monitors application-level traffic for specific applications
- The firewall is a proxy for the data received and sent from the application
 - The traffic to the application is sent to the firewall
 - The firewall relays data between the application and the clients
- Usually there will be different firewalls for different applications
 - ➔ FTP firewall (e.g., configured to accept downloads but not uploads, or viceversa)
 - ➔ Anti-SPAM email filters

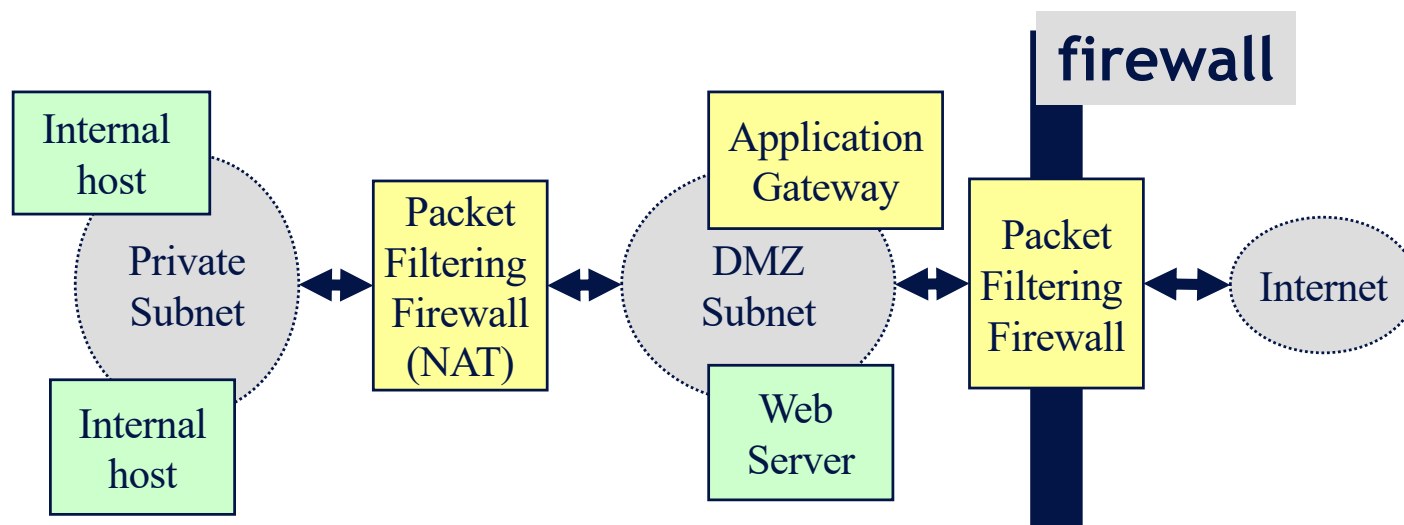
Mixed solution: Screened subnet

- The firewall accepts connections for some exposed services on known (exposed) ports.
It does D-NAT towards the application gateway
(D-NAT = (destination) network address translation)
- Application gateways then control the traffic, acting as proxy for the actual services

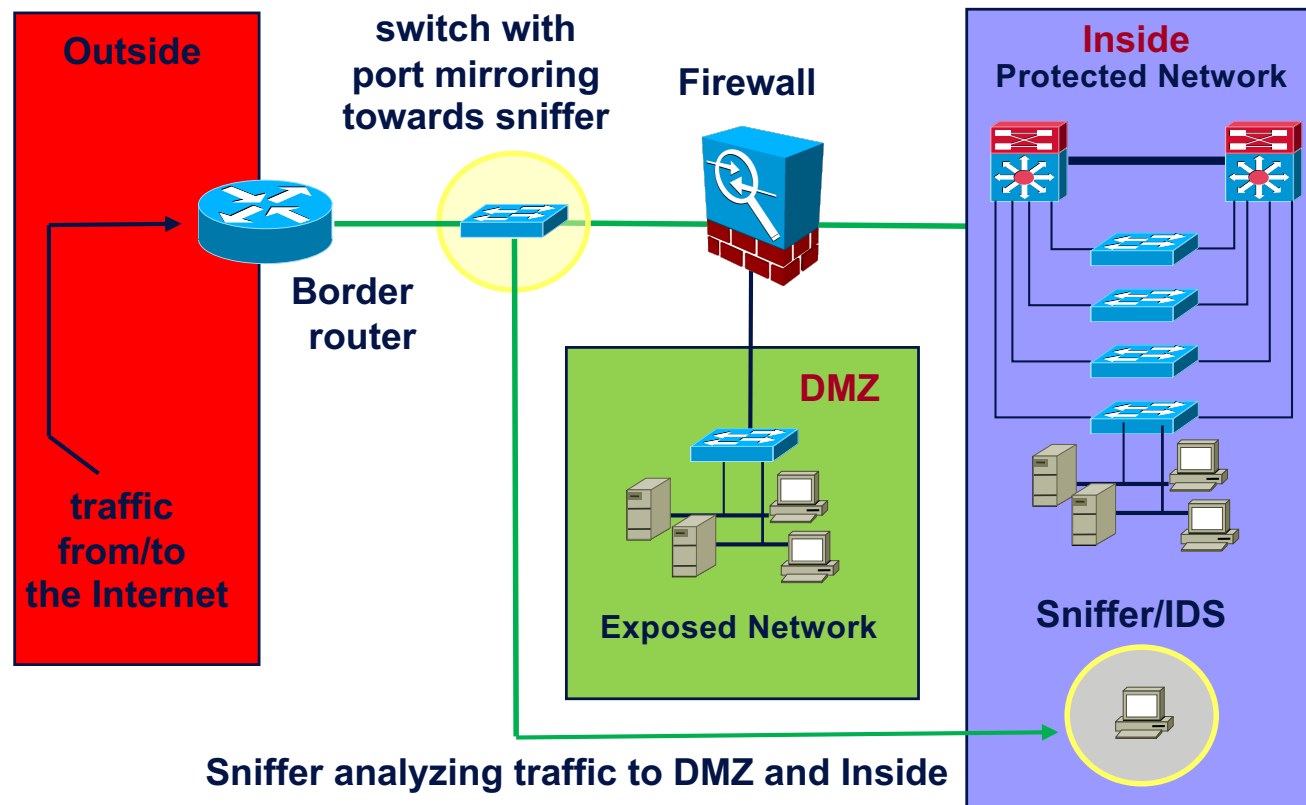


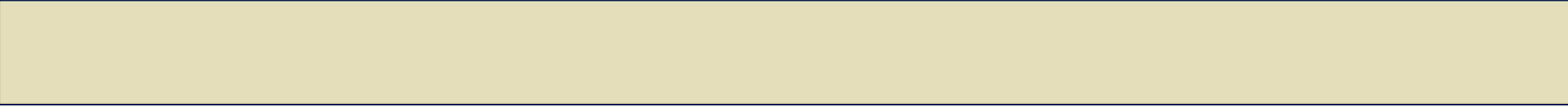
Mixed solution: DMZ

- DMZ = demilitarized zone
- Internal users and exposed services on separated network segments

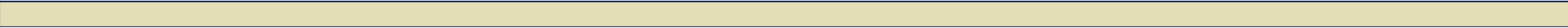


A Basic security architecture



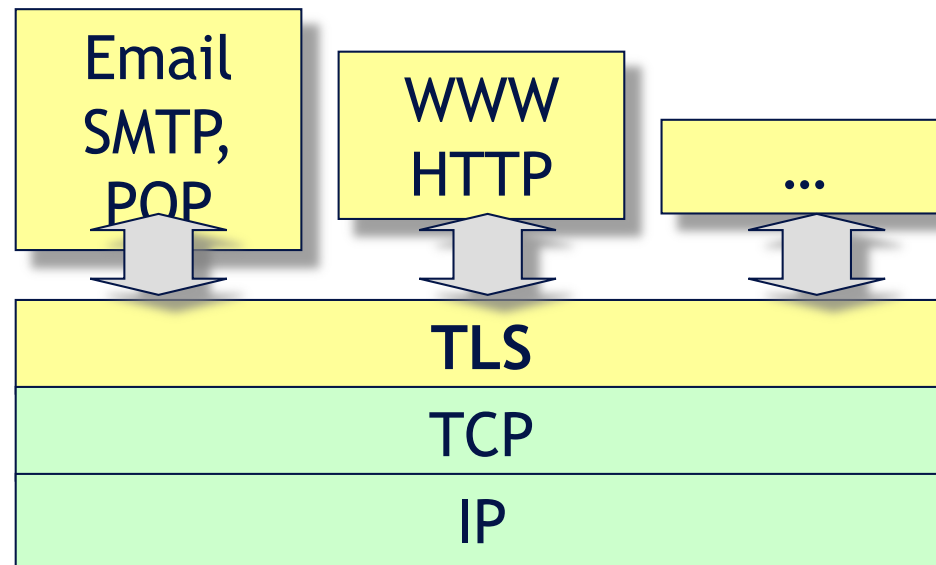


Protocolli di rete con crittografia



TLS: Transport Layer Security

- Successor of the now-deprecated **SSL** (Secure Sockets Layer)
- Privacy and integrity of application data over TCP/IP



TLS encapsulation (with encryption)

- TLS (SSL) encapsulates the application data in encrypted format
- Header TLS: info to allow receivers to know how to decipher

IP packet



5 bytes:

- type (1 byte),
- version (2 byte),
- length (2 byte)

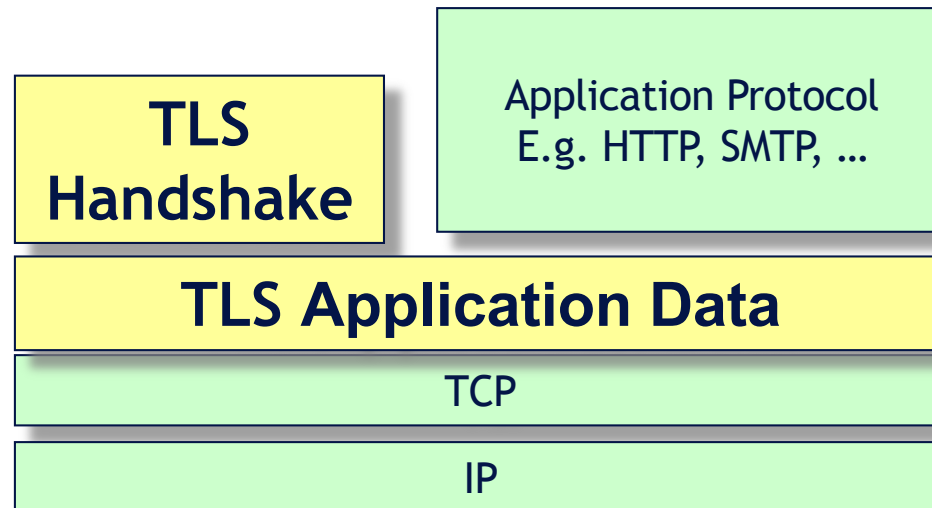
TLS sub-protocols

▪ Handshake Protocol

- to establish authenticated, protected connections (including key exchange)

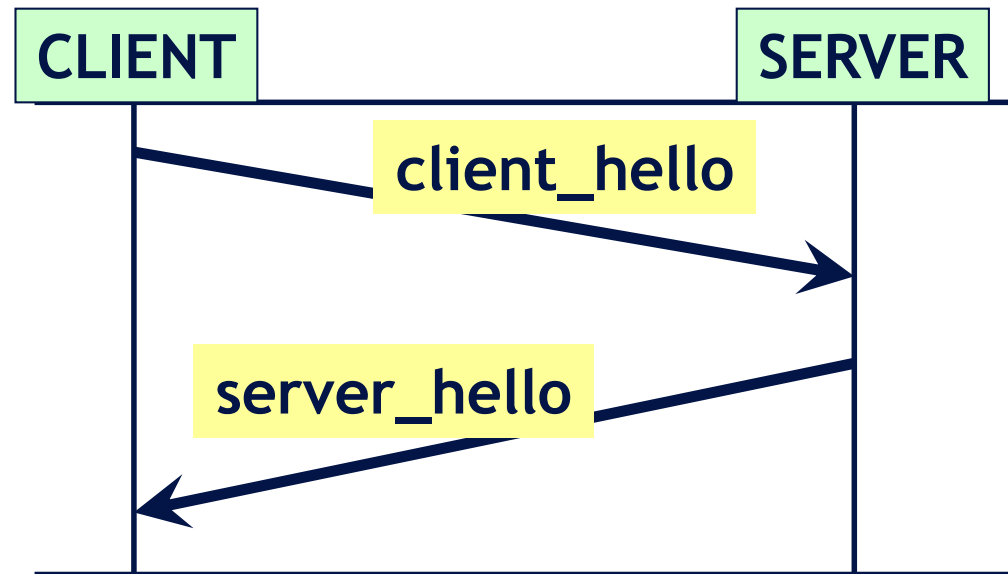
▪ Application Data Protocol

- to exchange encrypted application data



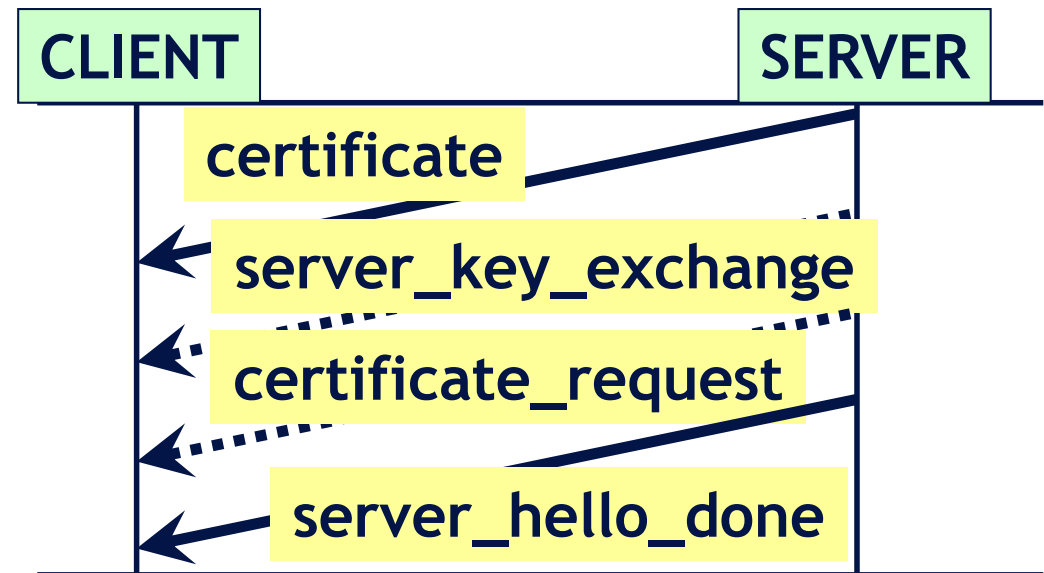
TLS Handshake: Hello Phase

- Hello messages include basic information for the parties to synch on how to interpret the data
 - TLS protocol version
 - session ID
 - a random number from client/server
 - Cypher suite
which cryptographic algorithms client supports / server selects



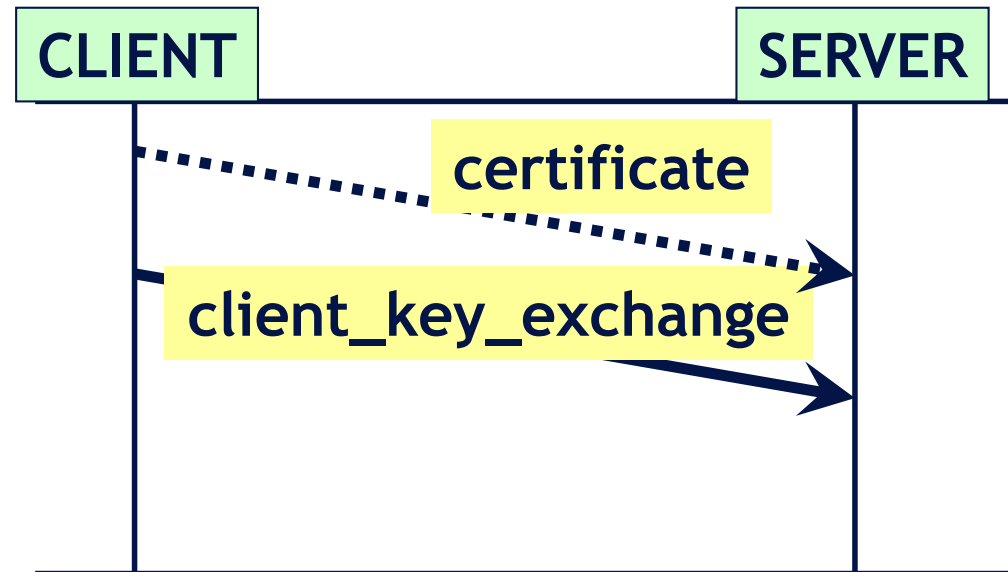
Handshake: Server Authentication Data

- Including
 - Sever X.509 certificate
 - Server key exchange
if the parties are not using RSA for key-exchange (the master secret), then these are the Diffie-Hellman parameters for key exchange
 - Certificate request
if the server requires client to authenticate



Handshake: Client Key Exchange

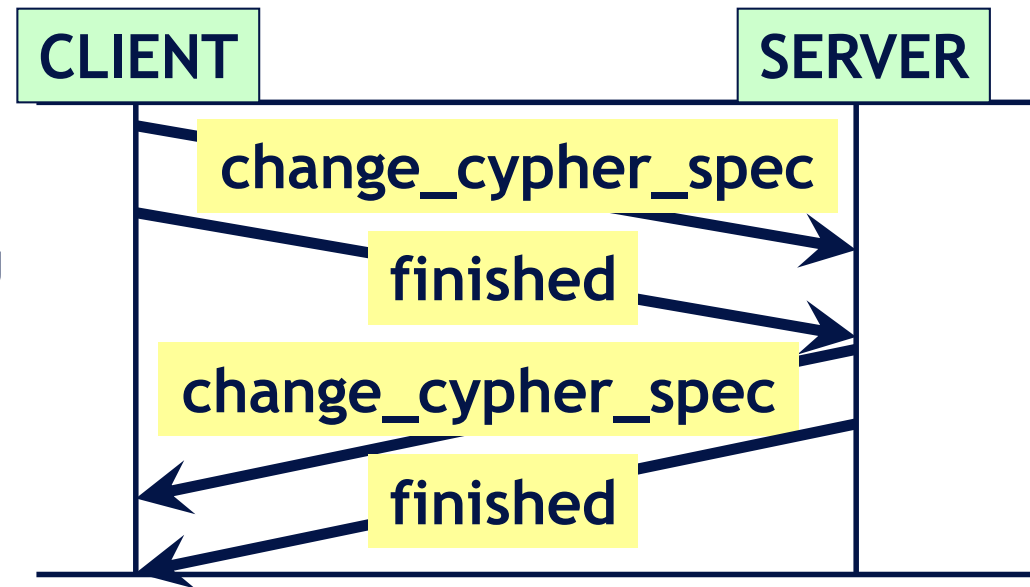
- Including
 - Client X.509 certificate if requested
 - Client key exchange
 - a) with RSA: random number encrypted with server's public key
 - b) with Diffie-Hellman: Diffie-Hellman parameters for key exchange



After this step, client and server can build the **master key**, using the random numbers exchanged in hello messages and as result of the **Client key exchange message**. Next communications will be encrypted by **symmetric cryptography** with the master key

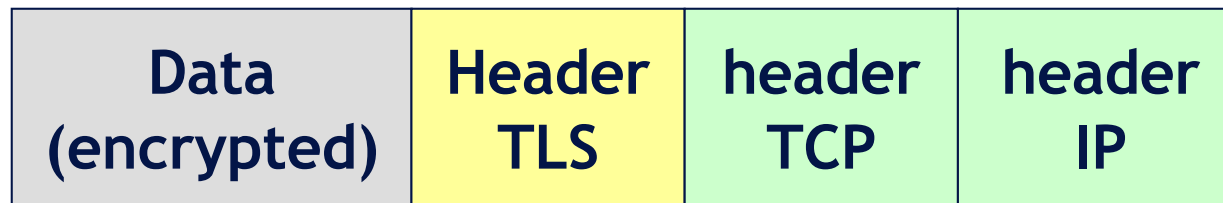
Handshake: Finish

- Including
 - **Change_cypher_spec**
confirm that the cypher-suite is set, and all next communications will be encrypted
 - **Finished (encrypted handshake)**
encrypted finish message, containing the hash of all previous messages



Application Data sub-protocol

- Once the TLS Handshake is successfully completed, the applications can begin communicating with each other, exchanging data in encrypted format

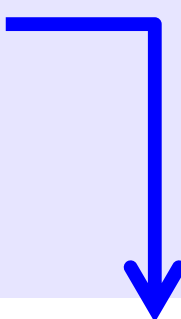


5 bytes:

- type (1 byte),
- version (2 byte),
- length (2 byte)

Example of TLS session (with gmail)

7973	55.897258	149.132.62.224	31.13.86.36	TLSv1.2	273	Client Hello
7975	55.902632	31.13.86.36	149.132.62.224	TLSv1.2	1450	Server Hello
7977	55.902635	31.13.86.36	149.132.62.224	TLSv1.2	481	Certificate, Server Key Exchange, Server Hello Done
7981	55.903252	149.132.62.224	31.13.86.36	TLSv1.2	192	Client Key Exchange, Change Cipher Spec, Encrypted Handshake Message
7982	55.906981	31.13.86.36	149.132.62.224	TLSv1.2	324	New Session Ticket, Change Cipher Spec, Encrypted Handshake Message
7983	55.906985	31.13.86.36	149.132.62.224	TLSv1.2	147	Application Data
7986	55.910163	149.132.62.224	31.13.86.36	TLSv1.2	159	Application Data
7987	55.910322	149.132.62.224	31.13.86.36	TLSv1.2	104	Application Data
7988	55.910387	149.132.62.224	31.13.86.36	TLSv1.2	321	Application Data
7989	55.913729	31.13.86.36	149.132.62.224	TLSv1.2	104	Application Data
7992	55.914810	31.13.86.36	149.132.62.224	TLSv1.2	108	Application Data
7994	55.954539	31.13.86.36	149.132.62.224	TLSv1.2	1088	Application Data



```
► Transmission Control Protocol, Src Port: 443, Dst Port: 56246, Seq: 3442, Ack: 334, Len: 81
▼ Secure Sockets Layer
  ▼ TLSv1.2 Record Layer: Application Data Protocol: http2
    Content Type: Application Data (23)
    Version: TLS 1.2 (0x0303)
    Length: 76
    Encrypted Application Data: 23e46b0cae69d0d5ac5b0f80aa849bdeee fd1549f77f8dea...
```

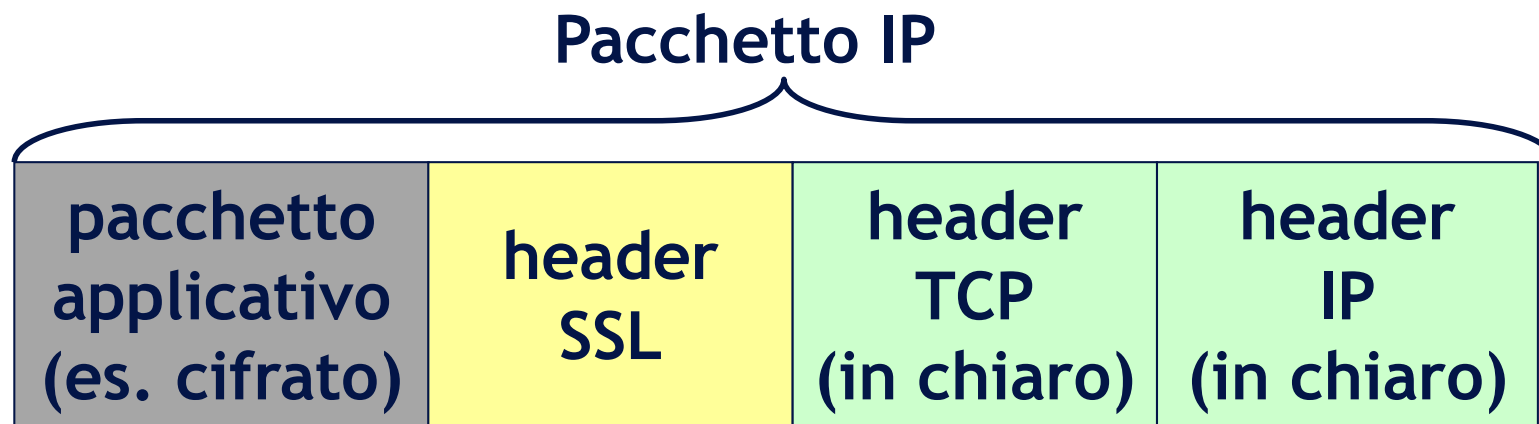
- Quali dati potete dedurre circa la comunicazione intercorsa?
- Quali sono i dati applicativi in un pacchetto “Application Data”?
- Quali sono i protocolli coinvolti nella comunicazione?
- Su quale porta TCP è in ascolto il server?

Sicurezza nelle Applicazioni Web

- HTTPS = HTTP su SSL/TLS
 - ➔ HTTPS ascolta sulla porta TCP 443 (invece HTTP porta 80)
- I componenti coinvolti devono implementare il layer SSL (integrando opportune librerie)
 - ➔ Browser
 - ➔ Server Web
 - ➔ Eventuali Proxy Server
- Ulteriori servizi offerti da SSL/TLS alle applicazioni
 - ➔ Message compression
 - negoziando gli algoritmi di compressione in fase di handshake
 - ➔ Session resuming
 - sfruttando l'unicità del SessionID

Limiti di SSL

- SSL (TLS) protegge la comunicazione fra applicazioni, aggiungendo sicurezza al di sopra dello strato di trasporto
- Le informazioni di trasporto e di rete sono in chiaro

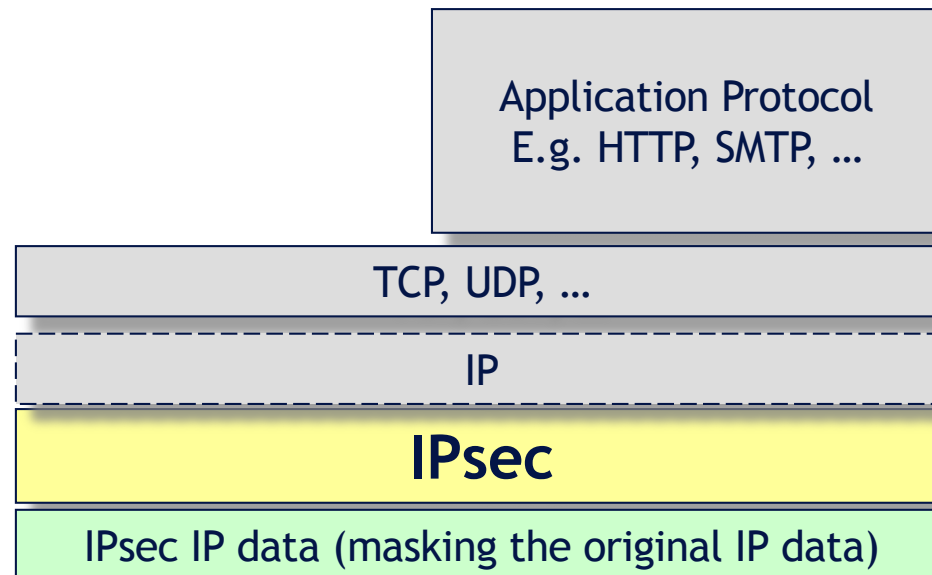


Vulnerabilità

- spoofing degli indirizzi IP
- analisi del traffico di rete
- ...

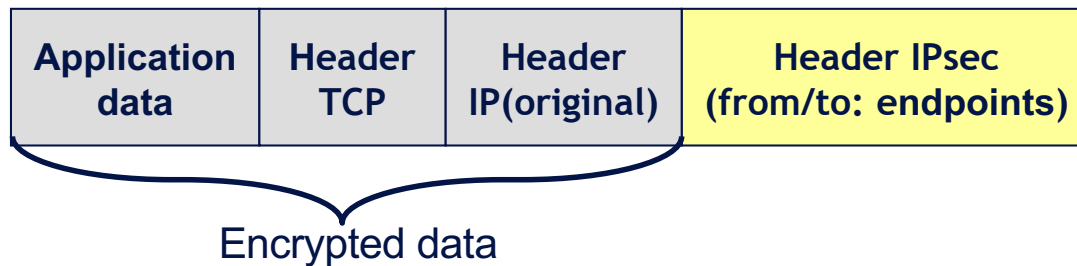
IPsec: IP Level Security

- Works with host-to-host configuration (transparent to applications)
- Host-to-host protection (but only host-to-host, not app-to-app)
- E.g. used for establishing VPN (Virtual Private Network) communications



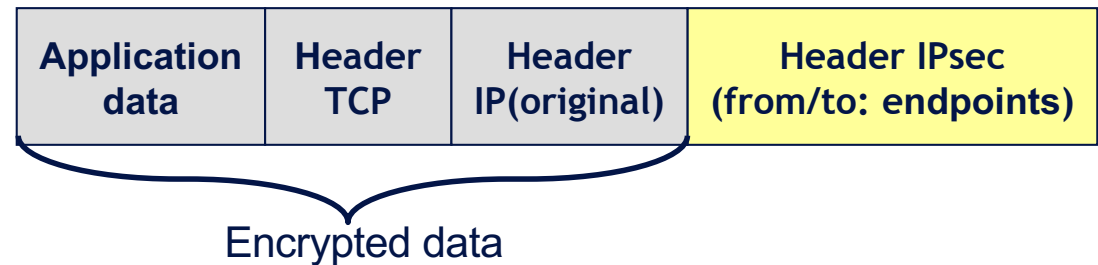
IPsec encapsulation (with encryption)

- IPsec encapsulates also the **TCP/IP** data in encrypted format

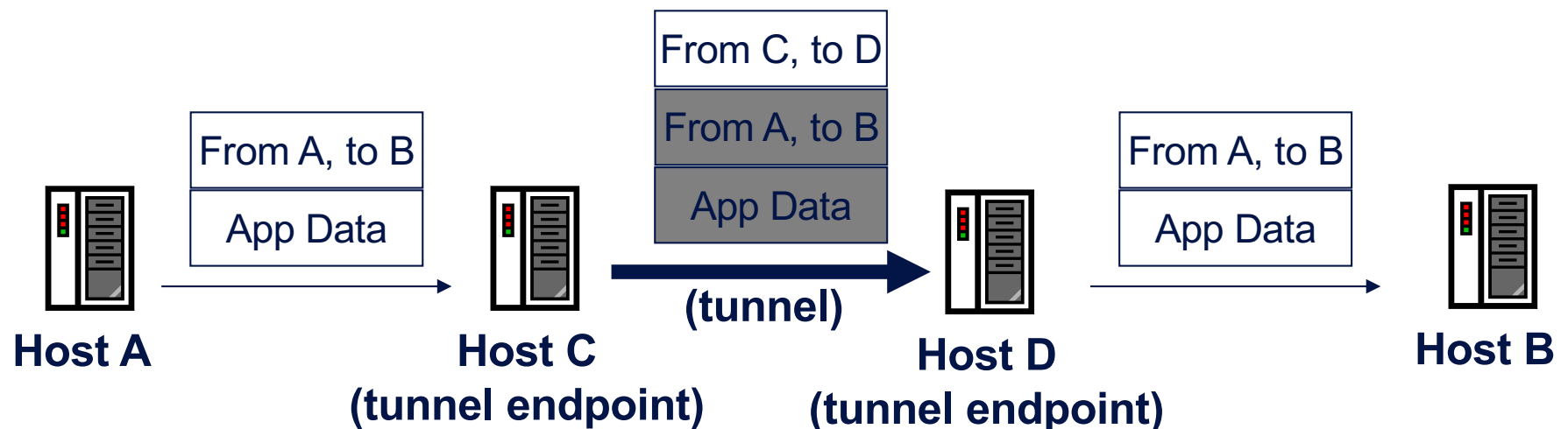


IPsec encapsulation (with encryption)

- IPsec headers specify the addresses of two routers (tunnel endpoints) configured to mutually encrypt/exchange any packet sent through them

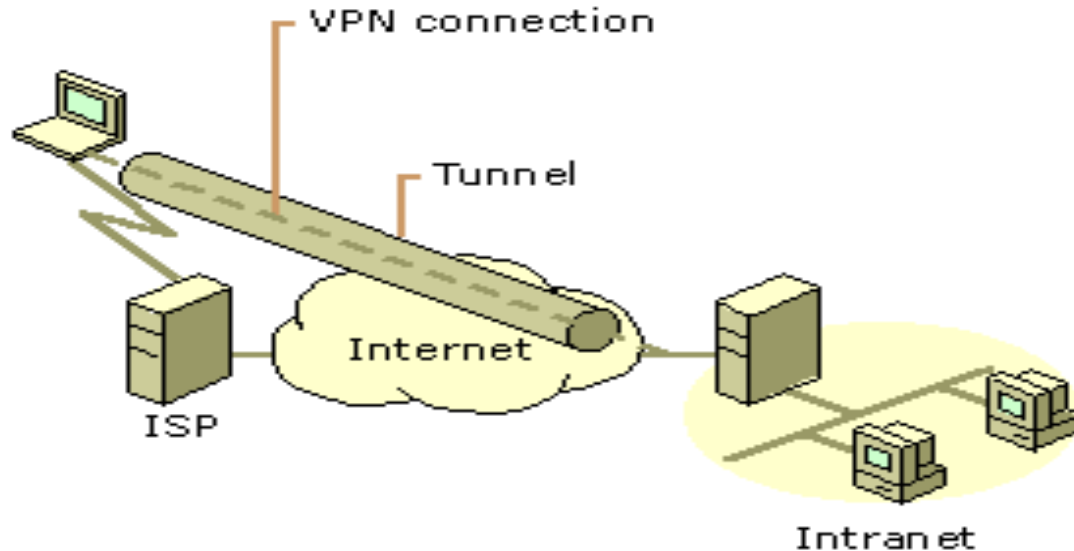


- Initial endpoint:** packets are encrypted/redirected to other endpoint
- Receiving endpoint:** packets are decrypted/directed to actual destinations



Virtual Private Networks (VPN)

- VPN connections are often used
 - E.g., between an employee working at home and a company
 - E.g., between different local networks of a company
 - All traffic between the endpoints is encrypted



VPN session (with gmail, as before)

	Time	Source	Destination	Protocol	Length	Info
1	0.000000	149.132.176.34	149.132.62.224	PPP Comp	192	Compressed data
2	0.000088	149.132.62.224	149.132.176.34	PPP Comp	107	Compressed data
3	0.007705	149.132.176.34	149.132.62.224	PPP Comp	107	Compressed data
4	0.015612	149.132.176.34	149.132.62.224	PPP Comp	380	Compressed data
5	0.015720	149.132.62.224	149.132.176.34	PPP Comp	107	Compressed data
6	0.016120	149.132.62.224	149.132.176.34	PPP Comp	107	Compressed data
7	0.059402	149.132.176.34	149.132.62.224	PPP Comp	192	Compressed data
8	0.059536	149.132.62.224	149.132.176.34	PPP Comp	107	Compressed data
10	0.078108	149.132.62.224	149.132.176.34	PPP Comp	1451	Compressed data
11	0.116817	149.132.176.34	149.132.62.224	PPP Comp	156	Compressed data
12	0.116963	149.132.62.224	149.132.176.34	PPP Comp	277	Compressed data
13	0.154427	149.132.176.34	149.132.62.224	PPP Comp	192	Compressed data
14	0.154591	149.132.62.224	149.132.176.34	PPP Comp	107	Compressed data
18	0.220494	149.132.176.34	149.132.62.224	PPP Comp	107	Compressed data
19	0.269096	149.132.176.34	149.132.62.224	PPP Comp	188	Compressed data
20	0.269255	149.132.62.224	149.132.176.34	PPP Comp	107	Compressed data
21	0.271131	149.132.62.224	149.132.176.34	PPP Comp	224	Compressed data
23	0.463423	149.132.176.34	149.132.62.224	PPP Comp	103	Compressed data
25	0.587392	149.132.176.34	149.132.62.224	PPP Comp	188	Compressed data
26	0.587532	149.132.62.224	149.132.176.34	PPP Comp	107	Compressed data
27	0.685234	149.132.176.34	149.132.62.224	PPP Comp	164	Compressed data
28	0.685376	149.132.62.224	149.132.176.34	PPP Comp	95	Compressed data

- Quali sono i protocolli coinvolti nella comunicazione?
- Quali dati potete dedurre circa la comunicazione intercorsa?

Ipsec: recap

- Protect traffic between two specified hosts (tunnel endpoints)
- The hosts can be
 - ➞ the gateways of two local networks
 - ➞ a user computer and the gateway of a remote network

Ipsec: Difese contro attacchi di rete

- Maggiore resistenza a sniffing e modifica dei dati
 - ➞ Usare IPsec anche congiuntamente altri protocolli di crittografia (ad esempio TLS)
 - IPsec protegge le informazioni dei protocolli superiori
 - Più livelli di crittografia → Più difficile decifrare
- Maggiore protezione contro traffic analysis
 - ➞ Uso della crittografia a livello di rete per tutti i messaggi
 - Lo scopo applicativo di una comunicazione diventa indistinguibile (seppure alcune analisi statistiche restano possibili)
 - ➞ Quando possibile, meglio costruire pochi tunnel fra sottoreti invece che molti tunnel per comunicazioni fra macchine specifiche
 - Mescola più tipi traffico in un unico tunnel
- Maggiore protezione contro IP spoofing
 - ➞ anche l'indirizzo IP d'origine viene autenticato